

## **SIMATS ENGINEERING**

### **ASSESSMENT TOOL 1**

**COURSE NAME: Ethical Hacking**

**COURSE CODE: ITA14**

#### **COURSE OUTCOME COVERED**

**CO2:** Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT3)

**Name:** Reddy Dorniya

**Reg No:** 192372061

#### **1. Nmap Scan Analysis**

##### **Answer**

##### **Analysis of the Scan Report**

The Nmap scan performed on **192.168.1.10** identified three important open ports: **22 (SSH)**, **80 (HTTP)**, and **3306 (MySQL)**. In addition, the scan detected the operating system and the versions of the services running on the target machine. Open ports indicate that the system is providing network services, but if these services are not properly secured, they may become entry points for attackers.

##### **Security Risks of Identified Services**

###### **1. SSH (Port 22)**

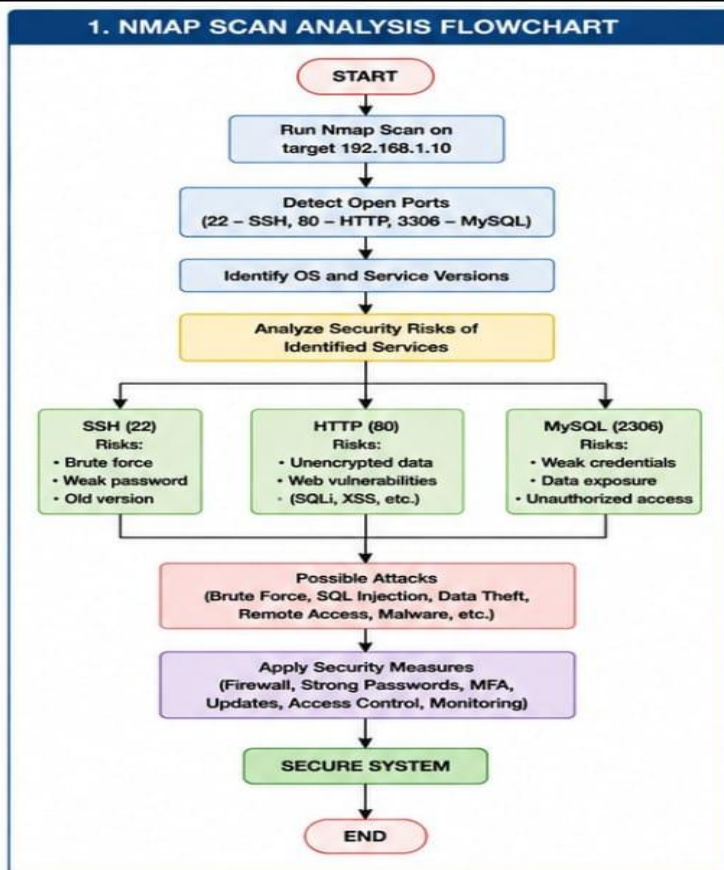
SSH (Secure Shell) is used by administrators for secure remote login and system management.

##### **Security Risks**

- Weak passwords can be cracked using brute-force attacks.
- Older SSH versions may contain publicly known vulnerabilities.
- If root login is enabled, attackers can gain full administrative control.
- Poor key management may lead to unauthorized access.

##### **Possible Exploitation**

- Automated password attacks using tools such as Hydra.
- Exploiting outdated SSH software vulnerabilities.
- Stolen SSH keys can allow attackers to log in without passwords.
- Attackers can install malware or steal confidential information after gaining access.



## 2. HTTP (Port 80)

HTTP is commonly used to host websites and web applications.

### Security Risks

- Data is transmitted without encryption.
- Sensitive information may be intercepted during communication.
- Poorly developed web applications may contain security flaws.
- Misconfigured servers may expose confidential files or directories.

### Possible Exploitation

- SQL Injection to access or manipulate databases.
- Cross-Site Scripting (XSS) to steal user sessions.
- Directory Traversal attacks to access hidden files.
- Remote Code Execution if vulnerable applications are installed.

- Website defacement by modifying web pages.

### **3. MySQL (Port 3306)**

MySQL stores application and business data.

#### **Security Risks**

- Public database access increases attack opportunities.
- Weak database passwords can be easily guessed.
- Default user accounts may still be enabled.
- Sensitive customer and organizational information may be exposed.

#### **Possible Exploitation**

- Brute-force login attempts.
  - Database dumping to steal confidential records.
  - Data manipulation or deletion.
  - Privilege escalation using vulnerable database accounts.
- 

### **Operating System and Version Detection**

The Nmap scan also identifies the operating system and service versions.

#### **Security Implications**

- Attackers can search vulnerability databases such as CVE or NVD for known exploits.
- Older software versions are more likely to contain unpatched security flaws.
- Information gathered during scanning helps attackers plan targeted attacks.

#### **Recommended Security Measures**

- Disable services that are not required.
- Keep the operating system and applications updated with the latest patches.
- Enforce strong passwords and enable Multi-Factor Authentication (MFA).
- Disable root login through SSH.
- Restrict MySQL access to localhost or trusted IP addresses.
- Use HTTPS instead of HTTP.
- Configure firewalls to allow only authorized traffic.
- Enable Intrusion Detection and Prevention Systems (IDS/IPS).
- Regularly perform vulnerability assessments and security audits.

- Monitor logs to detect suspicious activities.

## Conclusion

The Nmap scan reveals valuable information about the target system. Open ports and outdated services increase the attack surface and may allow attackers to compromise the system. Implementing secure configurations, applying software updates, restricting unnecessary network access, and continuous monitoring significantly improve overall security.

---

## 2. GoPhish Phishing Awareness Campaign

### Answer

#### Analysis of the Campaign Report

A phishing simulation was conducted using the **GoPhish** tool to evaluate employee awareness. The results showed that **40% of employees clicked the phishing link, 20% entered their login credentials, and several employees downloaded the malicious attachment**. These findings indicate that employees require additional cybersecurity awareness training.

#### Security Weaknesses Identified

##### 1. Clicking the Phishing Link

Many employees failed to verify the authenticity of the email.

##### Risks

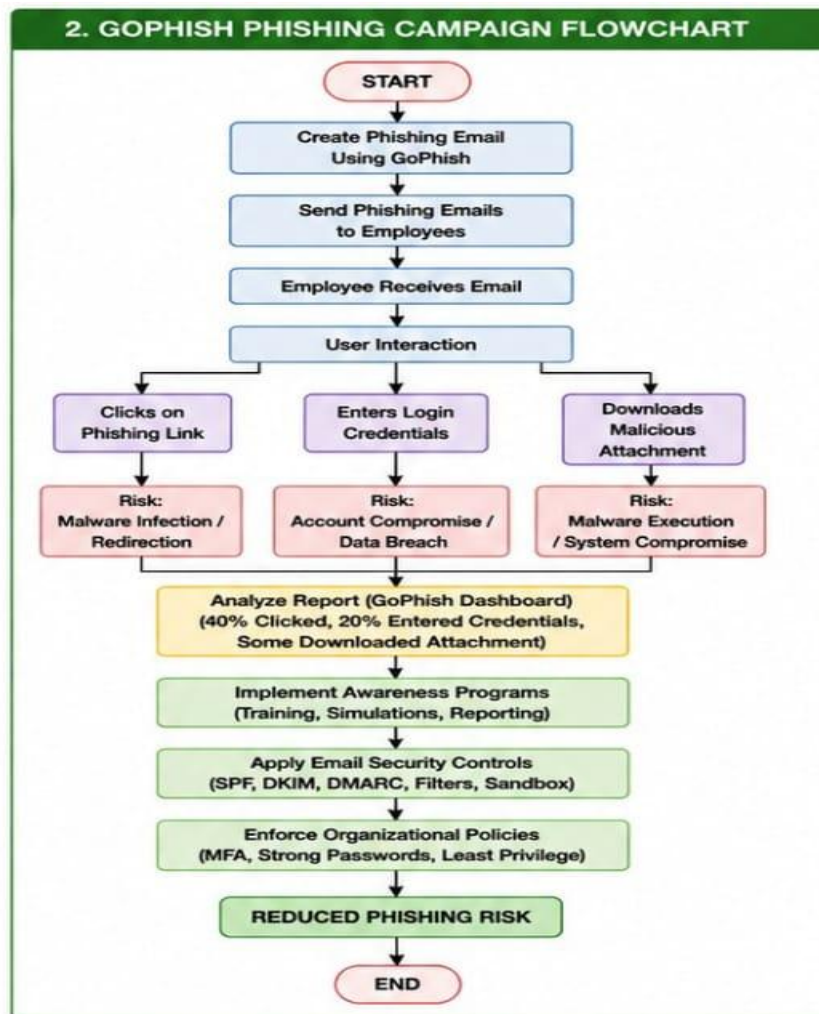
- Redirection to fake websites.
- Malware infection.
- Credential theft.

##### 2. Sharing Login Credentials

Some employees trusted the fake login page and entered their usernames and passwords.

##### Risks

- Unauthorized access to company systems.
- Identity theft.
- Financial loss.
- Data leakage.



### 3. Downloading Malicious Attachments

Several users downloaded infected files.

#### Risks

- Installation of ransomware.
- Spyware collecting confidential information.
- Complete system compromise.
- Spread of malware across the network.

#### Additional Security Weaknesses

- Employees did not verify the sender's email address.
- Users ignored suspicious spelling mistakes and unusual URLs.
- Lack of awareness regarding social engineering techniques.
- Failure to report suspicious emails immediately.

#### Recommended User Awareness Programs

- Conduct monthly cybersecurity awareness sessions.
- Organize simulated phishing campaigns regularly.
- Train employees to identify suspicious emails and fake websites.
- Educate staff about password security.
- Encourage employees to report phishing attempts immediately.
- Provide awareness posters and newsletters.
- Reward employees who correctly identify phishing emails.

### **Recommended Email Security Controls**

- Deploy advanced spam filtering solutions.
- Implement SPF, DKIM, and DMARC.
- Enable attachment scanning using antivirus software.
- Use URL rewriting and sandbox technology.
- Block dangerous attachment types.
- Enable email encryption where necessary.

### **Organizational Security Policies**

- Implement strong password policies.
- Enable Multi-Factor Authentication (MFA).
- Restrict administrative privileges.
- Maintain regular software updates.
- Establish an incident response plan.
- Conduct annual cybersecurity audits.
- Maintain secure backup procedures.

### **Conclusion**

The GoPhish campaign demonstrates that human error continues to be a major cybersecurity risk. Continuous employee education, strong authentication mechanisms, secure email filtering, and effective organizational policies can greatly reduce successful phishing attacks.

---

## **3. DNS Zone Transfer (Dig Tool) Analysis**

### **Answer**

### **Analysis of the DNS Assessment Report**

The DNS assessment performed using the **Dig** tool revealed that the organization's DNS server allows **DNS Zone Transfer (AXFR)** without proper authorization. This exposes the complete DNS zone database, including hostnames, IP addresses, mail servers, and DNS records.

### **Security Implications**

The exposed DNS information provides attackers with detailed knowledge of the organization's infrastructure.

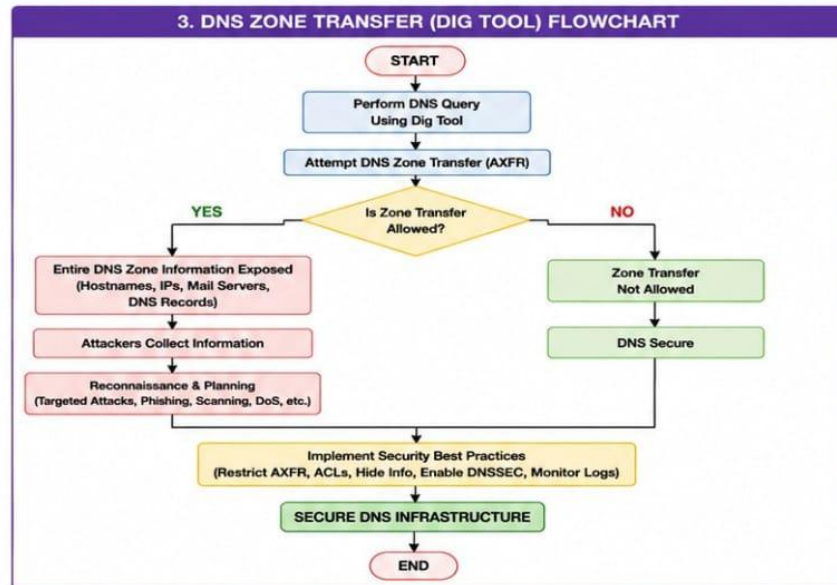
### **Potential Risks**

- Exposure of internal network topology.
- Identification of important servers.
- Discovery of mail servers and DNS architecture.
- Easier planning of targeted attacks.
- Increased attack surface.

### **How Attackers Can Exploit the Information**

An attacker can use the collected information to:

- Perform network reconnaissance.
- Identify vulnerable servers.
- Launch phishing attacks against mail servers.
- Conduct vulnerability scanning.
- Perform password attacks against exposed systems.
- Launch Denial-of-Service (DoS) attacks.
- Target domain controllers or critical infrastructure.



### Recommended Best Practices

- Disable unauthorized DNS Zone Transfers.
- Permit AXFR only between trusted primary and secondary DNS servers.
- Configure Access Control Lists (ACLs).
- Enable DNSSEC to protect DNS data integrity.
- Hide unnecessary DNS records from public view.
- Keep DNS server software updated.
- Monitor DNS logs regularly.
- Use split DNS to separate internal and external DNS information.
- Perform regular DNS security audits.
- Deploy firewalls to restrict DNS traffic.

### Benefits of Securing DNS

- Protects confidential network information.
- Prevents unauthorized reconnaissance.
- Reduces phishing and spoofing attacks.
- Improves overall network security.
- Enhances the availability and reliability of DNS services.

### Conclusion



An unrestricted DNS Zone Transfer allows attackers to gather valuable information about an organization's infrastructure before launching an attack. By restricting AXFR requests, enabling DNSSEC, implementing ACLs, and continuously monitoring DNS activity, organizations can significantly strengthen their DNS security and reduce the risk of cyber threats.